

Section 5 Cheat Sheet -- IAM & Service Accounts

GCP Study Notes

Study Notes April 2026

IAM Model

`WHO (Principal) + WHAT (Role) + WHERE (Resource) = Policy` – policies are **additive**, child inherits parent, deny policies can override.

Role Types

	Basic	Predefined	Custom
Managed by	Google	Google	You
Granularity	Very broad (thousands of perms)	Fine-grained, per service	Exact perms you pick
Examples	<code>roles/viewer</code> , <code>roles/editor</code> , <code>roles/owner</code>	<code>roles/compute.instanceAdmin.v1</code> , <code>roles/storage.objectViewer</code>	<code>projects/P/roles/myRole</code>
Scope	All resources	Specific service	Project or Org only
Production use	Avoid	Recommended	When predefined is too broad

- `roles/editor` does NOT include IAM management
- `roles/owner` = editor + IAM + billing
- Custom roles: max 3,000 perms, cannot be created at folder level, soft-deleted for 7 days

Key IAM gcloud Commands

```
# View policy
gcloud projects get-iam-policy PROJECT_ID

# Grant role
gcloud projects add-iam-policy-binding PROJECT_ID \
  --member="user:alice@example.com" --role="roles/compute.admin"

# Remove role
gcloud projects remove-iam-policy-binding PROJECT_ID \
  --member="user:alice@example.com" --role="roles/compute.admin"

# Conditional binding (time-based)
gcloud projects add-iam-policy-binding PROJECT_ID \
  --member="user:dev@example.com" --role="roles/editor" \
  --condition='expression=request.time < timestamp("2026-12-31T00:00:00Z"),title=temp'

# List / describe roles
gcloud iam roles list
gcloud iam roles describe roles/storage.objectViewer

# Create custom role
gcloud iam roles create myRole --project=PROJECT_ID \
  --permissions=compute.instances.get,storage.objects.list --stage=GA

# Test permissions
gcloud projects test-iam-permissions PROJECT_ID \
  --permissions=compute.instances.create
```

Service Account Essentials

```
# Create
gcloud iam service-accounts create my-sa --display-name="My SA"

# Assign to VM (at creation)
gcloud compute instances create my-vm \
  --service-account=my-sa@PROJECT.iam.gserviceaccount.com \
  --scopes=cloud-platform

# Assign to Cloud Run
gcloud run deploy my-svc --image=IMG \
  --service-account=my-sa@PROJECT.iam.gserviceaccount.com

# Impersonate
gcloud storage ls gs://bucket \
  --impersonate-service-account=my-sa@PROJECT.iam.gserviceaccount.com

# Set global impersonation
gcloud config set auth/impersonate_service_account my-sa@PROJECT.iam.gserviceaccount.com
```

- SA is both a **principal** (can be granted roles) and a **resource** (has its own IAM policy)
- Grant roles **TO** a SA = what it can do (`gcloud projects add-iam-policy-binding`)
- Grant roles **ON** a SA = who can use/manage it (`gcloud iam service-accounts add-iam-policy-binding`)
- Max **100** user-managed SAs per project
- Undelete within **30 days**

serviceAccountUser vs serviceAccountTokenCreator

	<code>roles/iam.serviceAccountUser</code>	<code>roles/iam.serviceAccountTokenCreator</code>
Purpose	Attach SA to resources	Create tokens / impersonate SA
Use case	Deploy VM or Cloud Run with that SA	Run gcloud with <code>--impersonate-service-account</code>
Grants	Permission to act as the SA via resource attachment	Permission to mint access/ID tokens for the SA

Scopes vs IAM Roles

Effective Permission = Scope INTERSECT IAM Role

- **Scopes** = legacy VM-level access gate
- **IAM roles** = modern, recommended control
- Best practice: always use `--scopes=cloud-platform` and control access purely via IAM roles
- Changing SA/scopes on an existing VM requires **stopping the VM first**

Workload Identity Federation (3 Steps)

1. **Create pool:** `gcloud iam workload-identity-pools create my-pool --location=global`
2. **Create OIDC provider:** `gcloud iam workload-identity-pools providers create-oidc github -
-workload-identity-pool=my-pool --issuer-uri=... --attribute-mapping=...`
3. **Bind SA:** grant `roles/iam.workloadIdentityUser` on the SA to the pool principal

Eliminates SA keys for external workloads (AWS, Azure, GitHub Actions).

Short-Lived Credentials

Type	Max Duration	Use Case
Access token	1 hour	API calls
ID token	1 hour	Auth to Cloud Run, etc.
Self-signed JWT	1 hour	Google API access
Signed blob	N/A	Sign data

```
gcloud auth print-access-token --impersonate-service-account=SA_EMAIL  
gcloud auth print-identity-token --impersonate-service-account=SA_EMAIL --audiences=URL
```

Best Practices

- Grant **least privilege** – prefer predefined over basic roles
- Use **groups** for access management, not individual users

- **One SA per application** – never share across services
 - **Never use default SAs** in production (they have `roles/editor`)
 - **Avoid SA keys** – prefer attached SAs, Workload Identity, or impersonation
 - Restrict key creation via org policy: `constraints/iam.disableServiceAccountKeyCreation`
 - **Disable** unused SAs before deleting
 - Use **IAM Recommender** to find over-provisioned access
 - Grant roles at the **narrowest scope** (resource > project > folder > org)
-

Exam Traps & Gotchas

- :warning: Policies are **additive only** – you cannot restrict an inherited parent permission at the child level with allow policies. Use a **deny policy** to block.
 - :warning: `roles/editor` does **NOT** let you manage IAM policies or billing.
 - :warning: Effective VM permissions = **scope INTERSECT IAM role**. A narrow scope blocks permissions even if IAM allows them.
 - :warning: You must **stop a VM** to change its service account or scopes.
 - :warning: `serviceAccountUser` = attach to resources. `serviceAccountTokenCreator` = impersonate/mint tokens. Do not confuse them.
 - :warning: Default Compute/App Engine SAs get `roles/editor` automatically – always replace with a dedicated SA.
 - :warning: Custom roles can only be created at **project or org level**, NOT folder level.
 - :warning: Deleted custom roles can be **undeleted within 7 days**; deleted SAs within **30 days**.
 - :warning: SA key files are long-lived secrets – if an exam answer involves keys vs. Workload Identity Federation, prefer WIF.
 - :warning: Conditional bindings require policy **version 3**.
 - :warning: `etag` in IAM policies prevents **race conditions** during concurrent updates.
-